

CVEs más relevantes de la semana

Del 04/08/2026 al 11/08/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-16443

Descripción: A flaw was found in the SAML metadata import functionality of the keycloak-services component, which is the core engine for identity brokering in Red Hat Build of Keycloak. When importing identity provider metadata that lacks specific usage attributes for keys, the system incorrectly disables signature validation for SAML responses even if a signing certificate is provided. This issue allows an...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-347

Tecnología: No especificado

Publicado el: 2026-08-05



CVE-2026-10025

Descripción: IBM QRadar 7.6.0.0 through 7.6.0.1, and 7.5.0 through 7.5.0 UP 15 Interim Fix 005 has an XML External Entity (XXE) injection vulnerability. The vulnerability resides in the `parseXmlPayload()` function within the event processing pipeline (`q1labs_core.jar`). When at least one log source type is configured to use XML-format property autodetection, the system processes XML-formatted syslog events ...

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:L

Tipo: CWE-611

Tecnología: No especificado

Publicado el: 2026-08-05



CVE-2026-16442

Descripción: A flaw was found in the SAML broker component of Keycloak, which is used to manage identity federation and user authentication. The issue occurs because the IdP-initiated Single Sign-On endpoint fails to check if a provider is restricted to account linking only. This allows an attacker with control over a linked upstream identity to bypass login restrictions and gain full access to a local user...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-346

Tecnología: No especificado

Publicado el: 2026-08-05



CVE-2026-8400

Descripción: IBM WebSphere Application Server 8.5, and 9.0 and IBM WebSphere Application Server - Liberty Continuous delivery has a flaw in the ORB component in IBM SDK, Java Technology Edition, may allow a malicious IIOP server to induce loading and instantiation of arbitrary classes.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-470

Tecnología: No especificado

Publicado el: 2026-08-05



CVE-2026-17617

Descripción: IBM Application Gateway Operator 22.2 through 26.06 is vulnerable to Server-Side Request Forgery (SSRF) due to insufficient validation of URLs specified in custom resources.

CVSS: 8.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-08-05



CVE-2026-8470

Descripción: IBM Langflow OSS 1.0.0 through 1.10.3, 1.0.0 through 1.10.3, 1.0.0 through 1.10.3, and 1.0.0 through 1.10.3 use Python's non-cryptographic random module for generating Fernet encryption keys from user secrets under 32 characters. The deterministic Mersenne Twister PRNG produces identical keys for identical seeds, allowing attackers to reproduce encryption keys and decrypt stored API keys and au...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-327

Tecnología: No especificado

Publicado el: 2026-08-05



CVE-2026-9205

Descripción: IBM Langflow OSS contains a weak cryptographic key derivation vulnerability in the `ensure_fernet_key()` function.

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-338

Tecnología: No especificado

Publicado el: 2026-08-05



CVE-2026-64993

Descripción: Dell RVTools versions prior to 4.8.1, contains an improper certificate validation vulnerability in the collector. A remote unauthenticated attacker could potentially exploit this vulnerability leading to loss of confidentiality and integrity.

CVSS: 6.8 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N

Tipo: CWE-295

Tecnología: No especificado

Publicado el: 2026-08-06



CVE-2026-54489

Descripción: Dell Virtual Storage Integrator for VMware vSphere Client, versions prior to 10.11.1.0, contain(s) a Sensitive Information Disclosure vulnerability. An unauthenticated remote attacker could potentially exploit this vulnerability, leading to information disclosure and session hijacking. This vulnerability is considered critical as it allows an unauthenticated attacker to obtain active session cr...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-200

Tecnología: No especificado

Publicado el: 2026-08-06



CVE-2026-62836

Descripción: Improper restriction of communication channel to intended endpoints in Azure SQL Managed Instance allows an unauthorized attacker to elevate privileges over a network.

CVSS: 8.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-923

Tecnología: No especificado

Publicado el: 2026-08-07



CVE-2026-56793

Descripción: Dell OpenManage Server Administrator, versions prior to 11.1.0.2, contains an Improper Authentication vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Unauthorized access.

CVSS: 7.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-08-07



CVE-2026-71956

Descripción: D-Link DWR-M961 devices with hardware version C1 and software version 1.1.2_C1_202602110044 contain a command injection vulnerability in the app.cgi interface. A remote attacker can inject arbitrary malicious commands into the netDig.ping.dst field, resulting in command execution with root privileges.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-08-08



CVE-2026-71957

Descripción: D-Link DWR-M961 devices with hardware version C1 and software version 1.1.2_C1_202602110044 contain a buffer overflow vulnerability in the app.cgi interface. A remote attacker can write an overly long string to the netAcc.addlist[].name field and execute arbitrary commands by crafting a specific payload, or cause the device to crash.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-120

Tecnología: No especificado

Publicado el: 2026-08-08



CVE-2026-71985

Descripción: MSI Radix AXE6600 router firmware version v781521 contains a command injection vulnerability in the accesscontrol function that allows remote attackers to execute arbitrary commands on the affected device. Attackers can exploit this vulnerability through the accesscontrol function to execute malicious commands and obtain root privileges on the underlying system.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-08-09



CVE-2026-71986

Descripción: MSI Radix AXE6600 router firmware version v781521 contains a command injection vulnerability in the dmz function that allows remote attackers to execute arbitrary commands on the affected device. Attackers can exploit this vulnerability through the dmz function to execute malicious commands and obtain root privileges on the underlying system.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-08-09



CVE-2026-71990

Descripción: MSI Radix AXE6600 router firmware version v781521 contains a command injection vulnerability in the TelnetSSH function used for SSH configuration that allows remote attackers to execute arbitrary commands on the affected device. Attackers can exploit this vulnerability through the SSH configuration interface to inject malicious commands and obtain root privileges on the underlying system.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-08-09



CVE-2026-71991

Descripción: MSI Radix AXE6600 router firmware version v781521 contains a command injection vulnerability in the TelnetSSH function used for Telnet configuration that allows remote attackers to execute arbitrary commands on the affected device. Attackers can exploit this vulnerability through the Telnet configuration interface to inject malicious commands and obtain root privileges on the underlying system.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-08-09



CVE-2026-14450

Descripción: A flaw was found in the MaaS API. This vulnerability allows any pod within the cluster to bypass the Kuadrant AuthPolicy gateway by forging HTTP headers, specifically `X-MaaS-Username` and `X-MaaS-Group`, which are trusted verbatim. This lack of first-party authentication enables an attacker to gain unauthorized access and escalate privileges. The concrete consequences include the ability to mi...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-08-10



CVE-2026-19425

Descripción: Travel Agency Management System developed by Win Men International has a SQL Injection vulnerability. Unauthenticated remote attackers can inject arbitrary SQL commands to read, modify, and delete database contents.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-08-11



CVE-2026-10579

Descripción: A flaw was found in Picketlink Federation SAML; the unsolicited response handler would accept forged assertions with no verification or validation, permitting an unauthed attacker to authenticate as any principal in any role. This could lead to information disclosure, access to restricted operations, or other flaws.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: N/A

Tecnología: No especificado

Publicado el: 2026-08-11



CVE-2026-58115

Descripción: A vulnerability has been identified in SIMATIC IoT2050 Advanced (6ES7647-0BA00-1YA2) (All versions < V4.3.4.1 running Industrial OS with Node-RED installed). Affected devices do not enforce authentication on the Node-RED HTTP interface, allowing unauthenticated access to programming nodes that are capable of executing system commands on the server. This could allow an unauthenticated remote at...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-08-11



Resumen del Reporte

CVEs analizados: 21

Promedio CVSS: 8.81

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

